

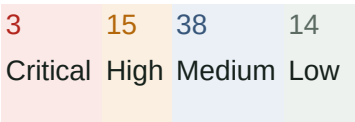
What stands between SiteComply and paying customers

A platform-wide audit of eight subsystems and the cross-cutting auth, security and engineering foundations — every finding read from current source, prioritised by business value and effort.

70 findings · 8 subsystems + cross-cutting · 5 parallel code audits · verified against docs/RBAC.md & live code
6 July 2026 · branch feature/archived-badge-style

Verdict

Architecturally sound and broad in scope — but not yet production-ready for external customers. The domain model, site-scoped data access and the settings/crypto layer are genuinely well-built, and core CRUD across every module works. Three things hold it back: a **critical authentication gap** (platform login accepts a hard-coded code in production), the **near-total absence of tests, CI and observability**, and a set of **unfinished compliance workflows** — notifications, reminders and document expiry — that are the product's core value for a construction-compliance buyer. The security blockers are small, sharp fixes; the reliability and workflow gaps are the real programme of work.



Readiness by dimension

Architecture & data model	4/5	Clean singleton-config pattern, indexed schema, disciplined site-scoping.
Security & auth	2/5	Mock login live in prod, no admin RBAC, no login rate-limiting.
Platform RBAC	3/5	Enforced & mostly consistent — sign-off, export & AI-role gaps; stale doc.
Reliability & operations	1/5	Zero tests, no CI, no error tracking, hand-run migrations.
Feature completeness	3/5	CRUD solid; notifications, reminders, expiry & photos unbuilt.

P0 — Critical: fix before onboarding any real customer

Each is a direct account-security exposure, live in production today. All three are small, well-scoped fixes; there is no reason to ship a paying customer before they land.

1 · Platform login accepts a hard-coded code 123456 in production

The platform sign-in verify route compares the submitted code against a fixed `DEV_CODE =`

`'123456'` with no `NODE_ENV` gate and no real email/SMS send. Anyone who knows an active

platform user's email or mobile can sign in as them and inherit their role and site scope — a full

authentication bypass for the office-user portal.

```
app/api/platform/auth/verify/route.ts:24,55 · app/api/platform/auth/start/route.ts:21,71
```

Fix: route platform login through the existing `otpService` (real SMS OTP, already rate-limited) or a

real email OTP channel; delete the constant. Value High · Effort M

2 · No brute-force protection on platform or admin login

Only worker SMS OTP is rate-limited. The platform verify endpoint can be hammered against 123456

with unlimited attempts, and admin auth has no throttle either. Combined with the fixed code above it

makes account takeover trivial and unmonitored.

```
app/api/platform/auth/** · app/api/admin/auth/** — no rate-limit primitive present
```

Fix: per-identifier + per-IP attempt caps and lockout on both login flows, reusing the OTP

challenge/cooldown pattern. Value High · Effort M

3 · Admin access is all-or-nothing — the `AdminRole` enum is never enforced

`AdminRole { OWNER, ADMIN, VIEWER }` is defined and assigned at first login, but no route ever

checks it — every settings route gates on `getAdminSession()` truthiness alone. A user provisioned

as a read-only VIEWER can change every setting and rotate SMS/AI provider credentials.

```
schema.prisma:53-57 · app/api/admin/settings/*/route.ts (session-only) ·
```

```
(dashboard)/layout.tsx:24-25
```

Fix: a `requireAdminRole()` helper; gate mutating settings routes to OWNER/ADMIN and make

VIEWER genuinely read-only. Value High · Effort M

Recommended sequencing

Ordered so each phase unblocks the next: close the security exposures, then build the safety net that lets you change code confidently, then finish the workflows that make the product saleable.

0

Security stop-the-bleed

— ~1 week, mostly small fixes

The three P0s plus the sharp-edged security bugs: the one-click worker-login logout, the public SVG-logo XSS, CSV formula injection in exports, document download that ignores the export policy, the AI role-leak, and the unthrottled public access-request endpoint.

X1 · X2 · X3 · S1 · S2 · R1 · D1 · AI1 · PAR1

1

Reliability foundation

— ~2–3 weeks

Make change safe: a CI gate (typecheck + lint + build), unit tests for the crypto/auth/RBAC primitives, error tracking with log-on-throw, global error boundaries, and folding the hand-run prod migration into an automated release step. Add admin session revocation and separate the secret-box key from the session secret.

Q1 · Q2 · Q3 · Q4 · Q5 · X4 · X5

2

Finish the compliance workflows

— ~4–8 weeks

The value the buyer is paying for: actually deliver notifications and overdue/reminder automation (the catalogue is built, nothing sends), document expiry & versioning alerting, admin user/role management, and the write-only audit-log viewers. Enforce the audit sign-off allow-list and de-dupe finding → action.

AC1 · PAR6 · S5 · D3 · S3 · AU1 · R4 · AI3 · F1

3

Hardening & polish

— ongoing

Pagination across every list, the placeholder scorecard/dashboard metrics, RBAC-doc refresh, reviewer tracking on rejection, unsaved-changes guards, shared validation schemas, and the long tail of UX nits.

R5 · R6 · D5 · AU5 · AC6 · PAR3 · S9 · Q6

Full findings register

Every finding in context, grouped by subsystem. Each carries its evidence (file:line), a recommended fix, and business-value / effort ratings. S = <½ day · M = ½–2 days · L = >2 days.

Cross-cutting · Auth & Security

Solid: AES-256-GCM secret box, HMAC-signed cookies, SSO with CSRF state, OTP never stored.

Sev	Finding & fix	Evidence · V/E
CRIT	X1 Platform login accepts hard-coded 123456 in production. Fix: route through real OTP; delete the constant.	verify/route.ts:24,55; start/route.ts:21,71 V High · E M
CRIT	X2 No brute-force protection on platform / admin login. Fix: per-identifier + per-IP attempt caps and lockout.	platform/auth/**; admin/auth/** V High · E M
CRIT	X3 Admin RBAC unenforced — AdminRole never checked. Fix: requireAdminRole(); gate mutations to OWNER/ADMIN.	schema.prisma:53-57; settings/*/route.ts V High · E M
HIGH	X4 Single SESSION_SECRET feeds 3 cryptosystems — rotation destroys stored secrets. Fix: separate SECRET_BOX_KEY; key-version rewrap.	session.ts:30,45; secretBox.ts:15; otpService.ts:42 V Med · E M
MED	X5 No admin session revocation; role snapshotted for 8h. Fix: token jti/version or per-request admin re-read.	session.ts:146-152 V Med · E M
MED	X6 CSRF relies solely on sameSite=lax; some mutations are GET. Fix: Origin/Referer check or CSRF token on state-changing routes.	all POST routes cookie-auth only V Med · E M
MED	X7 Secrets in App Service settings, not Key Vault; no restore runbook. Fix: Key Vault references; document + drill a restore.	DEPLOYMENT.md (documented, not built) V Med · E M

Cross-cutting · Engineering & Operations

Solid: TS strict, clean typecheck/build, well-indexed schema, repeatable (if manual) deploy.

Sev	Finding & fix	Evidence · V/E
HIGH	Q1 Zero automated tests — crypto, auth, RBAC & site-scope unverified. Fix: unit tests for secretBox/session/otp/config first.	no runner/test files; 58 route handlers V High · E M-L
HIGH	Q2 No CI gate on push/PR. Fix: ci → typecheck → lint → build (+ tests).	no .github/workflows V High · E S
HIGH	Q3 No observability — production 500s are invisible. Fix: log-on-throw at API boundary + error tracking + alerting.	no Sentry/App Insights; unlogged rethrows V High · E S-M

HIGH	Q4 Prod migrations run by hand, ordered by memory. Fix: fold migration into an automated, gated release step.	temp firewall + manual ordering V High · E M
MED	Q5 No global error / not-found boundaries. Fix: branded error + 404 boundaries.	no app/error.tsx / not-found.tsx V Med · E S
MED	Q6 No shared validation layer — hand-rolled per route. Fix: adopt zod DTOs incrementally.	no zod/yup V Med · E M
MED	Q7 Deploy branch is a feature branch, not main; fragmented branches. Fix: cut deploy over to main; reconcile branches.	feature/archived-badge-style V Med · E M
LOW	Q8 .nvmrc/engines pin Node 20; prod runs Node 22. Fix: bump pins to 22.	local ≠ prod runtime V Low · E S
LOW	Q9 SMS/AI test endpoints return raw error.message. Fix: map to a generic message; log detail server-side.	settings/sms/test:78; ai/test:70 V Low · E S

Reports

Solid: scope-intersection can't be widened by a forged param; exports gated & logged; Client aggregate-only is real.

Sev	Finding & fix	Evidence · V/E
HIGH	R1 CSV formula/injection not neutralised in exports. Fix: prefix leading = + - @ ; names are user-authored.	lib/csv.ts:9-12 V Med · E S
MED	R2 Export routes unbounded — memory / DoS / scraping risk. Fix: stream or cap rows; per-user export throttle.	attendance/export/route.ts:41 V Med · E M
MED	R3 canExportReport doesn't enforce directorOnly (latent). Fix: fold director-only rule into the export gate.	reportAccess.ts:22-31 V Med · E S
MED	R4 Export audit log is write-only — no admin viewing surface. Fix: admin view of who exported what.	reportExportLog.ts:37 unused V Med · E M
MED	R5 Scorecard Audits/Actions columns are permanent "—" placeholders. Fix: compute from modules, or hide until ready.	scorecard/page.tsx:119-120 V Med · E L
MED	R6 100-row cap tells non-export roles to "export CSV" — a dead end. Fix: pagination; hide export hint for non-export roles.	compliance/page.tsx:32,61 V Med · E M
MED	R7 Occupancy "on site now" list silently truncates at 100. Fix: add the truncation notice.	occupancy/page.tsx:55 V Med · E S
MED	R10 No scheduled/emailed reports, PDF/XLSX, or saved presets. Fix: roadmap — scheduled digest + richer formats.	CSV GET only V Med · E L
LOW	R8 Org-Overview "upcoming modules" tiles are static placeholders. Fix: wire to real modules or remove.	ExecutiveDashboard.tsx:108-126 V Low · E M
LOW	R9 Deselecting all sites silently means "all sites", not "none". Fix: distinguish empty selection.	reportFilters.ts:40 V Low · E S

Documents

Solid: full CRUD, private blobs, sanitised UUID keys, blob cleaned up on failed write, no IDOR.

Sev	Finding & fix	Evidence · V/E
HIGH	D1 Download gated on view, not export — Client/Engineer can exfiltrate files. Fix: gate download behind the export permission.	download/route.ts:24 V High · E S
HIGH	D3 No document expiry or versioning — a core compliance capability. Fix: expiry + alerting for RAMS/insurance/certs; version history.	no version/expiresAt on Document V High · E L
MED	D2 Delete mapped to edit verb — Engineer can destroy others' documents. Fix: a delete allow-list (as Audits use).	[id]/route.ts:72 V Med · E S
MED	D4 File type validated on client-declared MIME only. Fix: verify content signature (magic bytes).	documentService.ts:98 V Med · E M
MED	D5 No pagination — list returns all in-scope rows. Fix: paginate (shared with other lists).	documentService.ts:130-145 V Med · E M
MED	D7 File can't be replaced on edit — re-upload makes a new record. Fix: allow file replace within a document.	DocumentForm.tsx:221-224 V Med · E M
LOW	D6 Whole file buffered in memory on upload. Fix: stream to blob for large concurrent uploads.	documents/route.ts:62 V Low · E M

Audits

Solid: full CRUD + status lifecycle, deliberate delete allow-list, cascade to findings, generated actions SetNull-safe.

Sev	Finding & fix	Evidence · V/E
HIGH	AU1 AUDIT_SIGNOFF_ROLES defined but never enforced — a PM can sign off. Fix: enforce the sign-off allow-list on the status route.	platformPermissions.ts:205-209 unused; status/route.ts:25 V High · E S
MED	AU2 No transition rules; a signed-off audit can revert & clear its signatory. Fix: lock signed-off audits; restrict backward transitions.	setAuditStatus:260-261 V Med · E M
MED	AU3 Deleting an audit SetNulls linked actions — loses provenance. Fix: block/warn when linked actions exist.	schema.prisma:546 V Med · E S
MED	AU4 Audit photo uploads out of scope. Fix: roadmap — photo evidence on audits/findings.	new/page.tsx:43 V Med · E L
MED	AU5 No pagination on the audit list. Fix: paginate.	auditService.ts:158 V Med · E M

Audit Findings

Solid: create/read/update + quick status, scoped via parent audit, closedAt handled, severity → priority on action generation.

Sev	Finding & fix	Evidence · V/E
MED	F1 "Create action" has no idempotency guard — duplicates possible. Fix: guard/indicate when a finding already spawned an action.	AuditFindingsPanel.tsx:247; actionService.ts:418 V Med · E S
MED	F2 No DELETE for findings — only soft-close. Fix: allow removing a mistaken finding (or document intent).	no DELETE handler / deleteFinding V Med · E S
MED	F3 Finding → action link is one-directional in the UI. Fix: surface the linked action on the finding.	no back-link shown V Med · E M
MED	F4 Create-action / quick-status failures swallowed silently. Fix: surface non-OK responses to the user.	AuditFindingsPanel.tsx:79-108 V Med · E S
LOW	F5 listFindingsForAudit isn't itself site-scoped (latent footgun). Fix: scope the query itself as defence-in-depth.	findingService.ts:127-132 V Low · E S

Actions

Solid: every mutation site-scoped (no IDOR), completion-note gate enforced, reassignment audited via activity timeline.

Sev	Finding & fix	Evidence · V/E
HIGH	AC1 Overdue is derived-only — no scheduler, no reminder ever sent. Fix: a scheduled job + real delivery; headline compliance gap.	actionService.ts:143-148; channels available:false V High · E L
MED	AC2 Auditor can create free-hand actions — contradicts the RBAC doc. Fix: distinguish finding-originated from free-hand, or update doc.	actions/route.ts:23 V Med · E S
MED	AC3 assignedTo is free-text, not a user FK — can't notify an assignee. Fix: link assignee to a PlatformUser.	Action.assignedTo String? V Med · E L
MED	AC4 Hard delete cascades the entire activity timeline. Fix: soft-delete/archive to preserve the trail.	deleteAction:330; Cascade V Med · E M
MED	AC6 No "assigned to me" / search filter; no pagination. Fix: assignee filter, text search, pagination.	actions/page.tsx V Med · E M
LOW	AC5 Comments can't be edited or deleted. Fix: edit/delete own comments (or document immutability).	only addActionComment V Low · E M

Platform Access Requests

Solid: approval is transactional with email_taken handling; admin routes consistently gated; duplicate prevention on submit.

Sev	Finding & fix	Evidence · V/E
HIGH	PAR1 Public endpoint has no rate-limit / CAPTCHA — floodable. Fix: per-IP throttle + honeypot/CAPTCHA.	access-request/route.ts V High · E M
HIGH	PAR6 No requester notification on submit / approve / reject. Fix: email the requester on decision (shares AC1 delivery).	only in-app admin badge V High · E L
MED	PAR2 Account enumeration via distinct responses. Fix: uniform "if eligible you'll hear back" response.	access-request/route.ts:38-41 V Med · E S
MED	PAR3 Rejection never records who rejected. Fix: record reviewer on reject/reopen too.	reviewedByAdminId set only on approve V Med · E S
MED	PAR4 Reopen leaves an orphaned state → re-approve dead-ends. Fix: clean up created user + link on reopen.	setAccessRequestStatus:138-146 V Med · E M
LOW	PAR5 Reject is one-click — no confirm, no reason captured. Fix: confirm + optional reason surfaced to the requester.	AccessRequestList.tsx:134-141 V Low · E S

Settings

Solid: secrets never returned to client, AES-GCM at rest, consistent DB → env → default pattern, dev SSO fallback prod-gated.

Sev	Finding & fix	Evidence · V/E
HIGH	S1 Disabling SMS OTP can lock out every worker login — one click, no guard. Fix: confirm dialog + block saving with zero active OTP channels.	AuthConfigSettings.tsx:197 V High · E S
HIGH	S3 No admin user / role management. Fix: list/invite/demote/remove admins; assign roles.	no admins page/route (ties to X3) V High · E M
MED	S2 Public logo route serves admin-uploaded SVG — stored-XSS vector. Fix: drop SVG, or attachment disposition + strict CSP.	company/logo/route.ts:14-27 V Med · E S
MED	S4 No audit history of config changes — only last-writer. Fix: append-only admin change log (who/what/old → new).	updatedByName/updatedAt only V Med · E M
MED	S5 Stored-but-unconsumed: email OTP, notification channels, company branding. Fix: wire delivery + apply branding to real surfaces.	getNotificationChannels/ getCompanyBranding unused V Med · E L
MED	S9 docs/RBAC.md is stale — says "not yet enforced" when it is. Fix: refresh the source-of-truth doc; note CSCS export exceptions.	RBAC.md:3-8 V Med · E S
LOW	S6 No secret rotation / clear path. Fix: clear + rotate workflow (ties to X4).	overwrite-only merge V Low · E M
LOW	S7 SMS test requires a real send to a real handset. Fix: credential-validation-only test option.	sms/test/route.ts:62-72 V Low · E M
LOW	S8 No unsaved-changes warning; settings landing copy is	no beforeunload/dirty guard

stale.

Fix: dirty-state guard; refresh landing copy.

V Low · E S

AI Summaries

Solid: single enforced path (gate → authorize → scoped build → caps → log), ships OFF/404, secrets encrypted, deterministic cache + disclaimer.

Sev	Finding & fix	Evidence · V/E
HIGH	AI1 AI_ELIGIBLE_ROLES includes Client & Engineer — leaks worker-derived text to barred roles. Fix: drop Client/Engineer, or require export-capable roles for audit/action targets.	aiProviderCatalog.ts:96,99 V High · E S
MED	AI2 User free-text sent to the external model — PII / prompt-injection. Fix: strip/sanitise free-text or gate those targets tighter.	summaryTargets.ts:200-286; prompts.ts:56 V Med · E M
MED	AI3 AI usage / cost log has no viewing surface. Fix: admin usage/cost dashboard for the paid pilot.	aiSummaryLog.ts:9 V Med · E M
LOW	AI4 Cap enforcement has a TOCTOU race. Fix: atomic counter / transaction.	summaryService.ts:140-146 V Low · E M
LOW	AI5 No quota/cooldown feedback until a 429. Fix: show remaining quota / cooldown state.	AiSummaryPanel.tsx:43-69 V Low · E S
LOW	AI6 Summaries are ephemeral — no history / pin / share / cache purge. Fix: saved summaries + admin cache invalidation.	cache rows exist, no surface V Low · E M

What's genuinely solid

The foundations are good — this is a gap analysis, not a rewrite. Protect these while you close the gaps.

Disciplined site-scoping

Every read/write is constrained to the viewer's assigned sites as defence-in-depth; [id] routes 404 out-of-scope. No IDOR found across Documents, Audits, Findings or Actions.

Consistent settings architecture

Five config areas share one DB → env → default singleton pattern with live runtime getters; new providers/types are data-only additions.

Well-modelled AI safety path

All generation flows through one gate → authorize → scoped-build → caps → log chain; the feature ships OFF and 404s until configured.

Sound secret handling

AES-256-GCM with per-value IV + auth tag, HKDF domain separation, and secrets never returned to the client — only "is set" booleans.

Enforced report boundaries

Scope-intersection can't be widened by a forged parameter; exports are permission-gated and logged; Client aggregate-only is real, not cosmetic.

Clean build & schema

TypeScript strict, clean typecheck/build, 26 indexes covering the hot scoped-query paths, and a repeatable deploy runbook.

Method. Five parallel read-only code audits across the eight named subsystems plus cross-cutting auth, security and engineering. Every finding was read from current source on branch feature/archived-badge-style and cross-checked against docs/RBAC.md; claims of "missing" were confirmed absent, not assumed. Effort: S = <½ day, M = ½–2 days, L = >2 days. Severity blends security/data-integrity risk with business value. Estimates are order-of-magnitude for scoping, not commitments.